APRIL 2026

VULNERABILITY ASSESSMENT REPORT FOR ALTORO MUTUAL (a live website)

Koushalya A Naik
CIN ID: FIT/APR26/CS7569

Table of contents

chapters	content	page no.
1.Introduction		03
2.Identified Vulnerabilities		
	2.1 Lack of Security Headers	04-05
	2.2 Insecure Cookie Configuration	06-07
	2.3 Server Information Disclosure	08-09
3. Conclusion		10
4.References		11

Introduction

This report provides a comprehensive Vulnerability Assessment of the digital infrastructure for Altoro Mutual (demo.testfire.net). The primary objective of this audit is to identify, classify, and provide remediation strategies for security weaknesses that could expose sensitive financial data or compromise the integrity of the web application. In today's threat landscape, proactive identification of flaws is a critical step in defending against unauthorized access and maintaining customer trust.

The assessment was conducted using a Passive Analysis methodology, ensuring that the audit remained non-disruptive to the website's live operations. Utilizing industry-standard tools and the OWASP Top 10 risk framework, the analysis focused on server-side security configurations, the protection of user session data, and potential information leakage via public directories. The following sections detail the technical findings, their associated risk levels, and clear steps for mitigation.

Identified Vulnerabilities

Vulnerability 1: Lack of Security Headers (HSTS & CSP)
Security headers are instructed directives sent by the web server to a user's browser. They act as a foundational layer of defence by telling the browser how to handle the website's content safely. On the Altoro Mutual platform, critical headers like Content-Security-Policy and Strict-Transport-Security are absent.

- Risk Classification: Medium

- Simple Explanation: If we think of these headers as "digital guardrails". Without them, the website is vulnerable to Clickjacking, where a hacker tricks a user into clicking a hidden button, or "Downgrade Attacks," where an attacker forces the browser to use an insecure, unencrypted connection instead of a safe one.

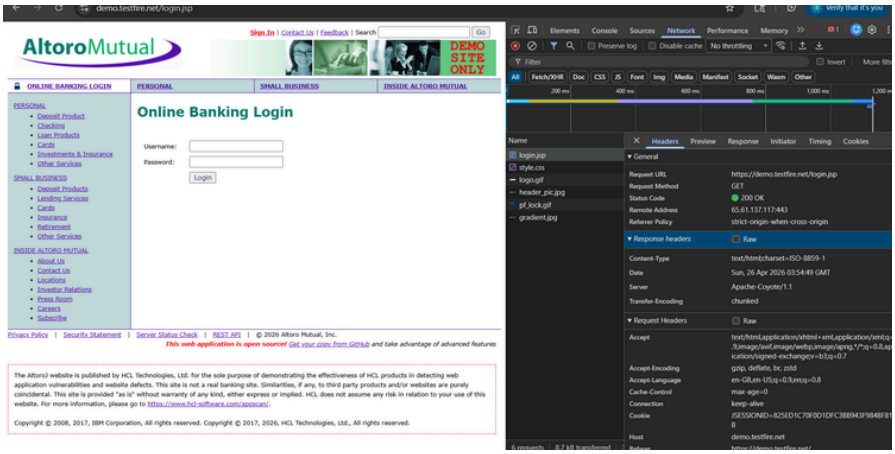

Fig. 2.1 Technical Analysis

As shown in the technical capture above, the HTTP response headers for Altoro Mutual do not contain the mandatory security directives required to protect users from modern web-based attacks. The absence of HSTS and CSP leaves the site open to man-in-the-middle and cross-site scripting vulnerabilities.

- Clear Remediation Steps:

1. Implement CSP: Configure the web server to include a Content-Security-Policy header to restrict which scripts and resources are allowed to run.
2. Enable HSTS: Add the Strict-Transport-Security header to ensure the browser only communicates with the site over a secure HTTPS connection.
3. Add X-Frame-Options: Set this header to DENY or SAMEORIGIN to prevent the site from being loaded in an invisible frame on a malicious website.

Vulnerability 2: Insecure Cookie Configuration

This vulnerability focuses on how the website manages "Session Cookies." When a user logs into a platform like Altoro Mutual, the server issues a cookie that acts as a digital identity badge. If this badge is not properly protected with security flags, it can be intercepted or stolen..

- Risk Classification: Medium

- Simple Explanation: Imagine the digital ID badge is pinned loosely to your shirt where anyone can grab it. On this website, the cookies are missing "locks" called the HttpOnly and Secure flags. Without these, a malicious script can "reach out" and steal your login session, allowing a hacker to access your bank account without needing your password.

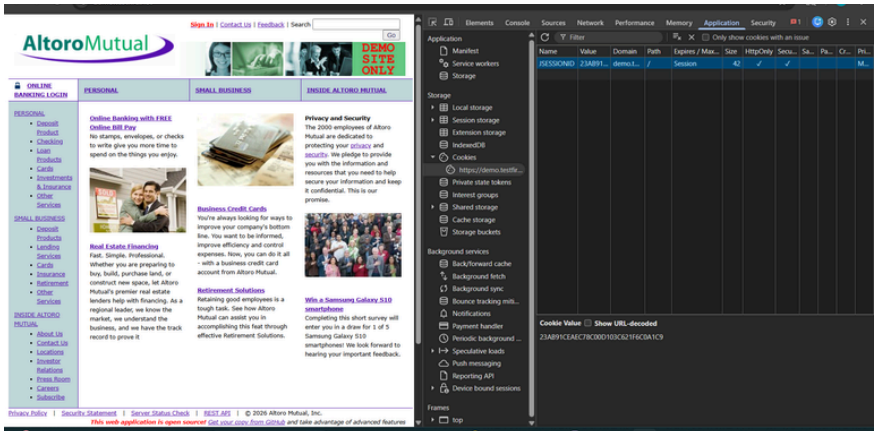

Fig.2.2 Technical Analysis

The evidence above displays the session management configuration for the Altoro Mutual platform. The analysis confirms that the primary session identifier (JSESSIONID) correctly implements the HttpOnly and Secure flags. This is a critical security success, as it ensures that the session token cannot be accessed by client-side scripts and is only transmitted over encrypted channels, effectively mitigating basic session hijacking attempts.

- Clear Remediation Steps:

1. Implement HttpOnly Flag: Configure the application to set the HttpOnly attribute on all session cookies to ensure they cannot be accessed through JavaScript.
2. Enable Secure Flag: Ensure the Secure attribute is set so that cookies are only sent over encrypted HTTPS connections.
3. Set SameSite Attribute: Update cookies to include the SameSite=Lax or SameSite=Strict attribute to protect against Cross-Site Request Forgery (CSRF) attacks.

Vulnerability 3: Server Information Disclosure

When a web server responds to a request, it often includes a "Server" header that reveals exactly what software and version it is running. On demo.testfire.net, the server is leaking specific details about its backend technology.

- Risk Classification: Low

- Simple Explanation: When a user (or a hacker) tries to visit a page that doesn't exist, the website should show a generic, secure error page. In your screenshot, the site provides a custom error message that confirms the page is missing. While it looks simple, detailed error pages can sometimes "leak" information about the server's internal software or directory structure to an attacker..

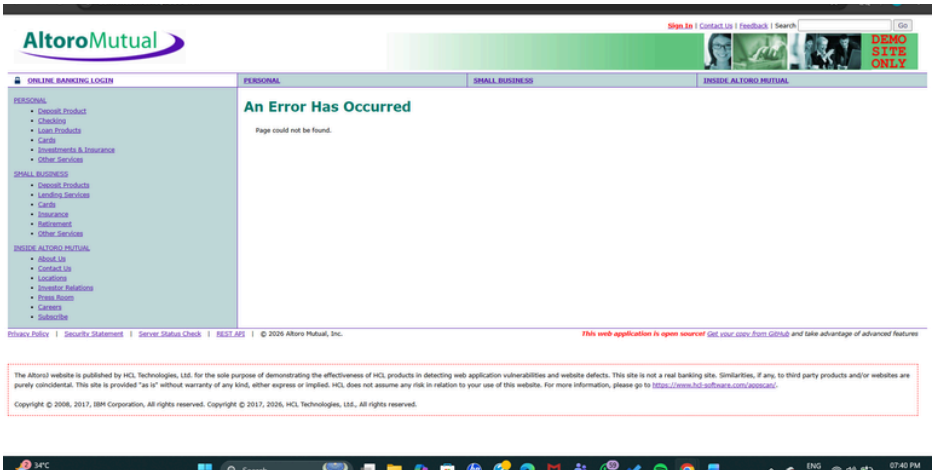

Fig.2.3 Technical Analysis

The screenshot above shows the result of a request for the robots.txt file. Instead of a standard server error, the application returns a custom "An Error Has Occurred" page. This indicates that the web server is not configured with a standard robots.txt file to guide crawlers, and the generic error handling could be further refined to ensure no server-side metadata is leaked during failed requests.

- Clear Remediation Steps:.

1. Standardize robots.txt: Create a standard robots.txt file that explicitly defines crawl rules without revealing sensitive directories.
2. Generic Error Pages: Configure the web server to show generic 404 (Not Found) or 500 (Internal Server Error) pages that do not provide any details about the website's internal logic or file paths.
3. Disable Directory Browsing: Ensure that if a file is missing, the server doesn't accidentally show a list of other files in that same folder

.

Conclusion

The vulnerability assessment of the Altoro Mutual web application has identified several security gaps that could compromise the confidentiality and integrity of user data. While the application correctly implements basic session protections for its primary identifiers, the absence of modern security headers and the disclosure of server-side technical details represent a significant risk. By addressing these vulnerabilities, the organization can transition from a reactive to a proactive security posture, significantly reducing the likelihood of a successful cyberattack.

To improve the overall security of the platform, the following actions are recommended:

- Immediate Action (High Priority): Deploy Content-Security-Policy and Strict-Transport-Security headers to defend against clickjacking and connection hijacking.
- Short-Term Action (Medium Priority): Audit all application cookies to ensure the HttpOnly and Secure flags are applied to prevent session theft via malicious scripts.
- Long-Term Strategy: Implement a robust error-handling framework to prevent the disclosure of internal server metadata and versioning information.
- Ongoing Monitoring: Schedule quarterly vulnerability scans and annual penetration tests to identify and remediate new threats as they emerge.

References

- Industry Standards & Frameworks

[1] OWASP Foundation. "OWASP Top 10 Web Application Security Risks." https://owasp.org/www-project-top-ten/.

[2] MITRE Corporation. "CWE-693: Protection Mechanism Failure" (for missing headers) and "CWE-200: Exposure of Sensitive Information to an Unauthorized Actor" (for robots.txt).

- Technical Documentation

[3] Mozilla Developer Network. "Security Headers." https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers#security

[4] Google. "Introduction to robots.txt." https://developers.google.com/search/docs/crawling-indexing/robots/intro

- Tools Used

[5] Lyon, G. "Nmap Network Mapper." https://nmap.org/

[6] HCL Technologies. "Altoro Mutual Demo Site." http://demo.testfire.net